

# praisonai-platform: Missing authorization on member removal enables full workspace takeover by any user regardless of role

Report Type: Weekly · Generated: May 31, 2026 05:30 UTC · Coverage: May 29 – May 31, 2026

|                  |          |      |        |
|------------------|----------|------|--------|
| 1                | 0        | 1    | 0      |
| Total Advisories | Critical | High | Medium |

## Executive Summary

## Summary \*\*Type:\*\* Authorization bypass enabling owner lockout. The `DELETE /workspaces/{workspace\_id}/members/{user\_id}` endpoint is gated only by `require\_workspace\_member(workspace\_id)` (default `min\_role="member"`). Any member can remove any other member, including the workspace owner, using a single DELETE. There is no caller-role check, no target-role check, no "cannot remove last owner" guard. \*\*File:\*\* `src/praisonai-platform/praisonai\_platform/api/routes/workspaces.py`, lines 130-140; `services/member\_service.py`, lines 71-78. \*\*Root cause:\*\* `MemberService.remove(workspace\_id, user\_id)` performs the deletion without any caller-permission check or owner-protection logic. The route accepts the URL-supplied `user\_id` and dispatches it straight through. The role hierarchy (`MemberService.has\_role`) is implemented but never invoked here. A member-tier attacker can issue `DELETE .../members/` and immediately lock the legitimate owner out of the workspace. ## Affe

**CONFIDENTIALITY NOTICE:** This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

| Advisory Title                                                                  | Severity | CVSS | EPSS       | AI Summary                                                                                  |
|---------------------------------------------------------------------------------|----------|------|------------|---------------------------------------------------------------------------------------------|
| prisonai-platform: Missing authorization on member removal enables full control | Critical | 9.8  | 0.00000000 | <p>## Summary</p> <p>**Type:** Authorization bypass enabling owner to remove any member</p> |

## MITRE ATT&CK;® Coverage

ATT&amp;CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

## Threat Actor Intelligence

Attribution analysis across advisories in this report period.

## Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for praisonai-platform: Missing authorization on member removal enables full workspace takeover by any user regardless of role.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK; techniques.

Appendix — Report Metadata & Legal

| Field          | Value                                           |
|----------------|-------------------------------------------------|
| Report ID      | intel--0a2f0bd516e6                             |
| Report Type    | Weekly                                          |
| Platform       | CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE |
| Generated At   | 2026-05-31T05:30:23.251313+00:00                |
| Customer Tier  | PRO                                             |
| Customer Email | —                                               |
| TLP            | TLP:CLEAR                                       |
| STIX Version   | 2.1                                             |
| ATT&CK Version | v15                                             |

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact [bivash@cyberdudebivash.com](mailto:bivash@cyberdudebivash.com).